



Customer 360 & CAR: Architecture Defense — Question and Answer

Nine questions a review panel is likely to raise against this design, answered directly and referenced back to Deliverables 1–3 and Part 2 – no stakeholder persona, no restaging of the question as someone else’s line of attack.

ARCHITECTURE DEFENSE — QUESTION AND ANSWER

Prepared For	Companion Documents	Status	Scope
Architecture review panel	#1 Architecture #2 ERD #3 Identity SQL Part 2	Draft for review	Nine questions across design trade-offs, privacy & governance, stakeholder enablement

How to Read This Document

Each item below states the question as asked, a direct answer, the reasoning behind that answer, and – where the claim rests on something already specified elsewhere – the exact section it comes from. Nothing here is attributed to a persona; a question is a question, not a line delivered by an engineering peer, a regulator, or an executive. Where an answer goes beyond what Deliverables 1–3 or Part 2 already state on the record, that is said explicitly rather than presented as an established fact.

1 Design Trade-offs

1.1 What did you prioritize for the Q2 launch versus defer to post-launch?

Answer: Identity resolution and its supporting controls came first; anything with a real dependency on the golden Customer 360, or without genuine Year-1 business necessity, was pushed to Day 90 or Year 2.

Explanation: The execution plan is one hard dependency chain – identity resolution has to be trustworthy before the golden 360 means anything, and the golden 360 has to exist before the CAR can be built on top of it. Day 30 ships the deterministic waterfall, the golden core tables, PII tiering, consent wired into onboarding, and a CAR skeleton with identity, balance, and transaction columns; PII tiering specifically is not deferred even at initial launch, since this is a regulated bank. Day 60 adds probabilistic matching once enough deterministic history exists to seed its labels, the full behavioral feature set, the automated data-quality gate, and the versioned schema contract the AI team builds against. Deferred past Day 90 into Year 2: household and relationship modeling, joint accounts, and the streaming layer for sub-daily fraud features. The household-modeling deferral is called out explicitly as a known, accepted trade-off rather than an oversight – Year 1’s actual use cases, personalization and the initial credit and fraud models, do not need



it to function.

Reference: Deliverable 1, Section 7 (30/60/90 Day Execution Plan); Section 3 (Customer 360 Schema) for the household-modeling deferral.

1.2 What are the two or three biggest technical risks in the design?

Answer: Two customers merging into one ECID, the token vault as a single point of re-identification failure, and the household and relationship fraud blind spot.

Explanation: The first two are rated low likelihood but critical impact: a bad merge cascades into every downstream artifact – CAR snapshots, model features, even a support conversation – before anyone catches it, and there is not yet a full remediation runbook for that blast radius, only the mechanical crosswalk fix; and the token vault is the one place all of the platform’s tokenization protection can be undone, which is why it carries dual-approval, break-glass, audit-logged controls, but it remains architecturally a single point of trust. The third, rated medium likelihood but high impact, is different in kind from the first two: it is not a degraded feature but a structurally invisible one, since the schema has no relationship edge between golden records at all today.

Reference: Part 2 (Trade-offs, Privacy & Stakeholder Q&A), Section 5 (Cross-Cutting Risk Register).

1.3 How would the architecture change if Mal scaled to 5 million customers?

Answer: The core design would not need to change; the identity-resolution approach, the PII tier model, and the CAR’s schema and grain are scale-agnostic. What would need tuning is operational.

Explanation: This goes beyond what is written in the deliverables – it is a reasoned extrapolation from the roughly 500K-customer baseline they specify, not a documented answer. The probabilistic-matching residual pool grows roughly with customer count, so blocking-key strategy and a move from full nightly rescoring to incremental scoring becomes worth doing. The CAR’s nightly full-snapshot rebuild would likely need to become incremental – recomputing only customers with new facts that day – to stay comfortably inside the 24-hour freshness ceiling. The single RDS read replica serving the mobile app and support console would probably need read-replica fan-out or a caching layer in front of it. Redshift’s SCD2 star schema itself scales into far higher row counts without a redesign.

Reference: Deliverable 1, Section 2 (Identity Resolution Strategy) and Section 5 (CAR v1 Schema), extrapolated beyond their stated Year-1 scale – not stated in the documents themselves.

2 Privacy & Governance

2.1 How do you handle consent withdrawal when a customer requests data deletion?

Answer: These are two different requests. Consent withdrawal already stops future computation of gated features; an actual erasure request is instead handled as re-tokenization and lockout, not a literal delete.

Explanation: The CONSENT entity records granted_at/withdrawn_at per consent type, and nothing is physically deleted at that layer – withdrawal simply means the nightly CAR job stops populating gated columns going forward. A genuine erasure request is harder, because CBUAE’s AML rules require five years of retention for identification and transaction records from account closure, which a literal delete would violate. The design’s direction is to rotate the customer’s PII tokens to non-reversible values and purge the token-vault entry, so historical rows survive for retention purposes but become permanently non-re-identifiable. That direction is not yet written down as a formal policy in Deliverable 1 – it should be, before this goes in front of Compliance.



Reference: Deliverable 1, Section 4 (PII Access Tier Model); Deliverable 2, Section 1 (Entity Dictionary, CONSENT); Part 2, Section 2 (Privacy & Regulatory Posture).

2.2 What happens when a user opts out of personalization but keeps their account?

Answer: Nothing else on the platform is affected – only the Engagement column group in the CAR is gated by personalization consent, and it is left null rather than computed and hidden.

Explanation: Consent is tracked per type, so personalization can be withdrawn independently of the account continuing to transact. Identity, balance, and transaction and risk fields are not gated at all, on a legitimate-interest basis for risk and fraud purposes. The design deliberately rejected computing personalization features and then masking them – withdrawn consent means those columns are left null, because computing them anyway wastes compute and leaves a standing exposure risk if a masking bug ever ships.

Reference: Deliverable 1, Section 4 (PII Access Tier Model, consent rationale) and Section 5 (CAR v1 Schema, "Gated by Consent?" column); Deliverable 2, Section 1 (CONSENT entity).

2.3 How do you audit PII access across teams?

Answer: Enforcement happens at the data layer across four tiers – Redshift dynamic masking plus Lake Formation column and row grants – not by application convention.

Explanation: Tier 0 sees aggregates only, with no PII columns present to leak. Tier 1 (AI/ML engineers, general analysts) gets tokenized pseudonyms via column-level masking. Tier 2 (support, KYC operations, compliance analysts) gets full PII but row-level security scoped to their assigned case, so access is inherently attributable. Tier 3 (named individuals, by approval) requires dual sign-off, and every single token-vault lookup is independently logged. Those Tier 2 and Tier 3 logs exist today but are not yet treated as a first-class, continuously monitored product – and they need to be, since breach-notification law requires answering which customers and which tier were affected within hours, not after a forensic review weeks later.

Reference: Deliverable 1, Section 4 (PII Access Tier Model); Part 2, Section 2 (Privacy & Regulatory Posture).

3 Stakeholder Enablement

3.1 How would you explain the CAR to a non-technical Product Manager?

Answer: It is one row per customer, refreshed every night, that already holds the answer to almost anything a credit or fraud model would need to ask.

Explanation: Without it, a model has to reconstruct a customer's balance trend, transaction pattern, and engagement from ten different tables every time it runs. With it, adding a new signal for a model to consider becomes "add a column to a table that already updates on schedule" instead of building a new pipeline.

Reference: Deliverable 1, Section 5 (CAR v1 Schema).

3.2 What SLA commitments can you make to the AI team, and what are the caveats?

Answer: Five committed targets – freshness, completeness, schema stability, data quality, and access – each with a named caveat.

Explanation: Freshness: a full prior-day snapshot published under 24 hours – a ceiling, not a target; it does not cover the minutes-scale refresh some fraud features will eventually need. Completeness: at least 99.5% of active customers present – this assumes the identity waterfall keeps the unmatched residual small, and is the number most likely to come under pressure first if probabilistic matching underperforms on real Day 60



data. Schema stability: no breaking change ships without a new version and a 30-day dual-publish window. Data quality: an automated gate blocks a bad publish and serves the last known-good snapshot instead. Access: pseudonymized by default, with re-identification only through an audited token-vault lookup.

Reference: Deliverable 1, Section 6 (AI Team Data Interface).

3.3 What is the communication plan for the 30/60/90 rollout?

Answer: A staged plan mirroring the same four audiences already used for stakeholder Q&A – engineering and compliance at Day 30, the AI team and product/executive stakeholders at Day 60, and a cross-stakeholder governance review at Day 90.

Explanation: This is a proposal, not something already written into the deliverables. At Day 30: a written confirmation to engineering and compliance that ingestion, tokenization, and PII tiering are live, since compliance needs that assurance before anything else ships. At Day 60: the schema contract and SLA table are formally published to the AI team as their actual go-live, alongside a product and executive readout on how FindMatches performed against the Day 30 assumptions. At Day 90: the first governance council review doubles as an honest checkpoint, presenting the risk register openly – including the two gaps this design set has already named, the erasure policy and the Redshift/RDS parity check – so those get decided in that session rather than drifting. After Day 90: any breaking schema change gets the 30-day dual-publish notice the SLA already commits to, and anything regulatory is escalated immediately, outside the regular cadence, given the breach-notification law’s own “immediate” standard.

Reference: Deliverable 1, Section 7 (30/60/90 Day Execution Plan); Part 2, Section 5 (Cross-Cutting Risk Register).